

SEGURIDAD INFORMÁTICA

UNIVERSIDAD POLITÉCNICA --- DE SAN LUIS POTOSÍ

NOMBRE DEL ALUMNO: Leonardo Serrano Zermeño

MATRICULA: 177301

FECHA: 06/03/2026

TÍTULO DE LA ACTIVIDAD: El eslabón más débil

Introducción.....	2
Marco teórico.....	2
1. Ingeniería social y el Vector de Phishing.....	2
2. Metodología de simulación educativa.....	3
3. Métricas críticas de resiliencia.....	3
4. Fundamentos de ética y privacidad digital.....	3
Análisis individual de las 8 plataformas.....	3
Hoxhunt.....	3
Proofpoint.....	4
KnowBe4.....	5
Cofense.....	6
Phished.....	7
NINJIO.....	8
Mimecast.....	9
Infosec IQ.....	10
Tabla técnica comparativa.....	11
Conclusión.....	12
Referencias Bibliográficas.....	13

Introducción

Actualmente la ciberseguridad sigue considerando al factor humano como el “eslabón más débil” dentro de la cadena de defensa de cualquier organización. A pesar de los avances en tecnologías de protección, los ataques de ingeniería social, y específicamente el phishing, continúan siendo el punto de quiebre y puerta de entrada principal para la vulneración de sistemas complejos. La presente investigación surge de la necesidad de abordar esta vulnerabilidad desde un punto de vista distinto al castigo, sino que desde la educación y el diseño responsable.

El objetivo general de este trabajo es el de diseñar, implementar y evaluar una simulación educativa de phishing con un enfoque ético. Este ejercicio no tiene el propósito de engañar al usuario de manera maliciosa, sino medir los niveles de conocimiento de los usuarios ante las amenazas de ingeniería social para fortalecer su capacidad de respuesta. La base de este diseño se sustenta en un análisis comparativo previo de las plataformas profesionales líderes en el mercado, asegurando que la simulación cumpla con los estándares de calidad y principios de privacidad digital.

Para darle estructura a esta investigación, se establecieron los siguientes hitos:

- **Análisis Comparativo:** Identificar y contrastar las capacidades técnicas, métricas de medición, enfoques de entrenamiento y, fundamentalmente los controles éticos de plataformas como HoxHunt, Proofpoint, KnowBe4, Cofense, Phished, NINJIO, Mimecast e Infosec IQ.
- **Diseño e implementación:** Llevar a cabo la creación de un Phishing Quiz interactivo compuesto por 10 escenarios realistas que integren retroalimentación formativa y un sistema de puntuación individual que garantice el consentimiento informado y la seguridad de las credenciales de los participantes.
- **Interpretación de resultados:** Desarrollar un sistema de Score global que permita el análisis de tendencias de desempeño y niveles de vulnerabilidad, facilitando la detección de oportunidades de mejora bajo un marco de ética digital.

Marco teórico

La ciberseguridad contemporánea ha evolucionado de un enfoque puramente perimetral hacia la Gestión de Riesgo Humano (Human Risk Management - HRM). Este cambio de paradigma reconoce que el factor humano es el vector de ataque más explotado, involucrando un elemento de manipulación en el 60% de las brechas de seguridad actuales.

1. Ingeniería social y el Vector de Phishing

La ingeniería social es el arte de manipular psicológicamente a las personas para que divulguen información confidencial o realicen acciones que comprometan la seguridad. El phishing es su variante técnica más extendida, utilizando el correo electrónico o mensajería para la suplantación de las identidades de confianza.

Para que una simulación sea efectiva, debe basarse en escenarios realistas que emulen las tácticas actuales de los atacantes, tales como el sentido de urgencia, autoridad o el miedo.

2. Metodología de simulación educativa

A diferencia de un ataque real, la simulación educativa busca la retroalimentación formativa. Según los objetivos de esta investigación, la simulación no es una prueba de “atrapado”, sino que se trata de una oportunidad de aprendizaje inmediato.

- **Momentos de enseñanza:** Se refiere al instante en el que un usuario interactúa con un elemento sospechoso. En este momento, la plataforma debe mostrar una explicación visual de las señales de alerta (pistas) que el usuario pasó por alto.
- **Diseño de escenarios:** Los 10 escenarios requeridos deben cubrir diversos niveles de dificultad y vectores para medir la resiliencia de forma integral.

3. Métricas críticas de resiliencia

Para evaluar la efectividad, se usan diferentes algoritmos que transforman el comportamiento humano en datos accionables:

- **Click rate (Tasa de clicks):** Mide la vulnerabilidad inmediata. La fórmula es la siguiente:
- $Click\ Rate = \left(\frac{Usuarios\ que\ hicieron\ click}{Total\ de\ correos\ enviados} \right) \times 100$
- **Reporting Rate (Tasa de reportes):** Es el indicador clave de una cultura de seguridad proactiva. Mide cuántos usuarios identificaron y utilizaron los canales oficiales para alertar.
- **Risk score (Puntuación de riesgo):** Un algoritmo predictivo que consolida el historial del usuario, su tiempo de respuesta y la criticidad de su puesto para generar un perfil de riesgo individual y grupal.
- **Dwell Time (Tiempo de permanencia):** Mide cuánto tarda un usuario en interactuar con el correo sospechoso desde que llega a su bandeja.

4. Fundamentos de ética y privacidad digital

El diseño de una campaña de ingeniería social debe regirse por principios éticos estrictos para evitar la erosión de la confianza organizacional:

- **Consentimiento informado:** Los participantes deben ser conscientes de que forman parte de un programa de entrenamiento.
- **No captura de credenciales:** Por seguridad y ética, bajo ninguna circunstancia se deben almacenar contraseñas o datos reales en los servidores de la simulación.
- **Seguridad Psicológica:** El sistema de puntuación y el ranking deben utilizarse para motivar y no para sancionar o avergonzar públicamente al “eslabón más débil”.

Análisis individual de las 8 plataformas

A continuación, se presenta el análisis de las 8 plataformas que se proponen como punto de referencia para el desarrollo de este proyecto.

Hoxhunt

Hoxhunt es una solución de formación en ciberseguridad, está centrada en la gestión del riesgo humano mediante inteligencia artificial que personaliza las simulaciones según el comportamiento del usuario. Tiene la filosofía de dar un refuerzo positivo en lugar del castigo. Esta plataforma se caracteriza por:

- **Simulaciones de Phishing Adaptativas:** Utiliza IA para crear escenarios de ataque personalizados que imitan amenazas reales, ajustándose automáticamente al nivel de riesgo de cada usuario.
- **Capacitación Gamificada:** Emplea elementos de juego para aumentar la participación, haciendo que el aprendizaje sobre ciberseguridad sea interactivo y ameno.
- **Reporte de Amenazas:** Incluye un botón para que los empleados reporten correos electrónicos sospechosos, facilitando la detección rápida de amenazas reales.
- **Gestión de Riesgo Humano:** Analiza el comportamiento del usuario para identificar vulnerabilidades y mejorar la seguridad general de la organización.

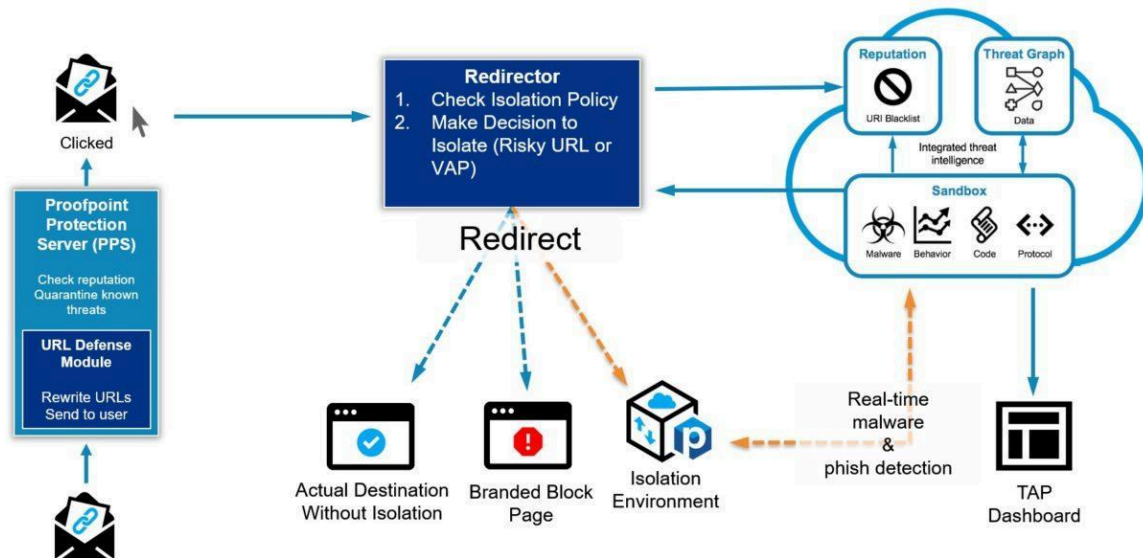


Proofpoint

Proofpoint es una de las empresas líderes globales en ciberseguridad y cumplimiento. Su enfoque es el de proteger el vector de ataque número uno: el correo electrónico. A diferencia de las defensas tradicionales que protegen la red o a los servidores, Proofpoint se especializa en proteger a los usuarios, basándose en la premisa de que los atacantes ya no hackean sistemas, sino que engañan a las personas.

Proofpoint se diferencia de la competencia por sus capacidades técnicas:

- **Identificación de VAPs (Very Attacked People):** Este sistema analiza quien recibe los correos más peligrosos o quien puede ser un objetivo de ataques dirigidos, esto permite que el departamento de seguridad asigne entrenamientos de seguridad más estrictos o controles técnicos solo a ciertas personas, en lugar de “molestar” a toda la empresa.
- **TAP (Targetted Attack Protection):** Es una capa de defensa técnica que analiza URLs y archivos adjuntos en tiempo real. Incluso antes de que llegue al usuario, Proofpoint abre los archivos en un entorno seguro para ver si se comportan de forma maliciosa.
- **PSAT (Proofpoint Security Awareness Training):** Esta parte se encarga de hacer simulaciones basadas en amenazas reales, asegurando que, si un usuario cae en una simulación, recibe un momento de enseñanza inmediato en el que se le explica cuál fue el error que cometió.



KnowBe4

KnowBe4 es una plataforma de simulación de phishing y formación en ciberseguridad que se basa en el principio de que la repetición y el contenido entretenido son la única forma de cambiar el comportamiento humano. Esta fue fundada por Stu Sjouwerman con la colaboración del famoso ex-hacker Kevin Mitnick.

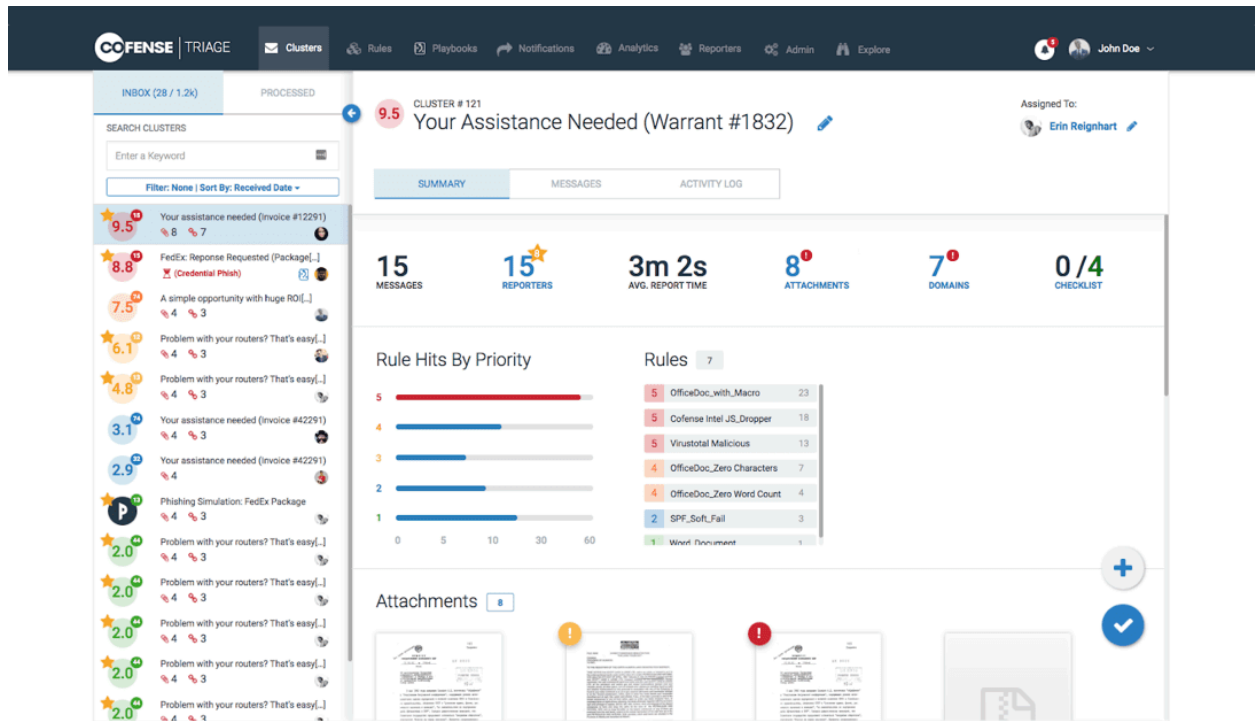
- **Extensa biblioteca de entrenamientos:** KnowBe4 cuenta con miles de piezas de contenido detrás de una subscripción. Desde series con calidad de televisión (un ejemplo es “the inside man”) hasta pósteres y módulos interactivos.
- **Smart Groups:** Si un usuario hace click en un correo de prueba, el sistema lo mueve automáticamente a un grupo de refuerzo el que le asigna un curso extra sin que el administrador tenga que hacer nada.
- **Métrica PPP (Phishing-prone Percentage):** Es la métrica de medición estándar de KnowBe4, y basa el éxito en la misma. Esta refleja la cantidad de usuarios vulnerables y la compara con el inicio del uso del sistema, con un año de uso para ver el avance de los usuarios.
- **AIDA (Artificial Intelligence Defense Agents):** Es un sistema de agentes de IA que automatiza la gestión del sistema. Analiza que tan bien le va al usuario, así como la creación de correos Phishing mediante IA, los cuales parecen estar escritos por humanos, haciendo las pruebas mucho mas realistas.



Cofense

Cofense (antes PhishMe) es una plataforma de seguridad centrada en la detección y respuesta colaborativa. Su lema implícito es que “la tecnología fallara, pero una red de humanos alerta puede detener el ataque”. Es la opción de preferencia de las empresas que tienen un SOC (Centro de Operaciones de Seguridad) muy activo, porque sus herramientas están diseñadas para que el reporte de un empleado se convierta en una acción de defensa.

- **Cofense reporter:** Fue de los pioneros en la estandarización del botón de reporte en Outlook/Gmail. La forma en la que funciona es premiando el reporte incluso si el usuario hizo click en el mail antes de reportarlo. Lo importante es que el equipo de seguridad se entere de que hay un ataque en curso.
- **Cofense Triage (análisis del SOC):** Soluciona las posibles saturaciones de los sistemas de TI causados por reportes masivos. Utiliza algoritmos para separar el spam de las amenazas reales de phishing.
- **Inteligencia colectiva:** Si un usuario de una empresa A reportar un phishing nuevo, Cofense se encarga de analizar esa amenaza y, casi instantáneamente alerta a la empresa B y C que hacen uso de la plataforma.
- **Cofense Vision:** Permite que el equipo de seguridad busque en todos los buzones de la empresa un correo que ya ha sido identificado como malicioso, con el motivo de borrarlo de forma masiva con un solo click, incluso si los usuarios no lo han visto.

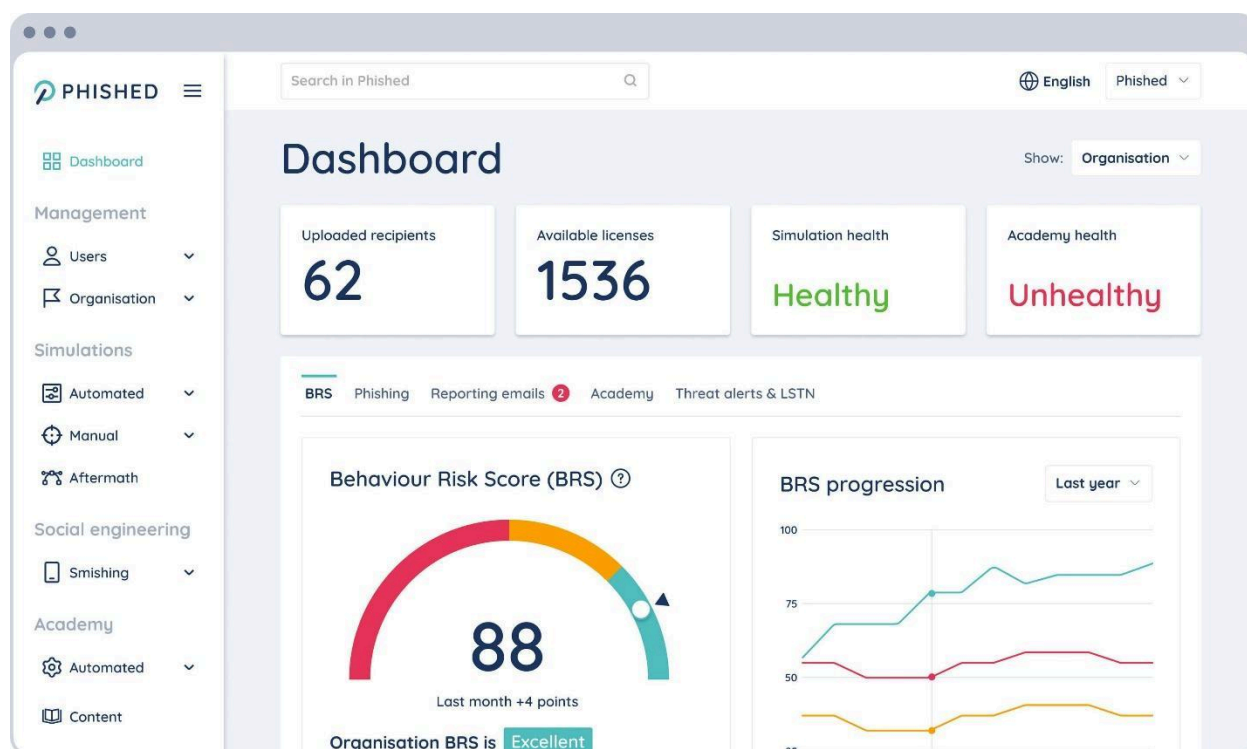


Phished

Phished es una solución de gestión de riesgo Humano que está diseñada para ser 100% automatizada. Su enfoque es la individualización extrema: no envía el mismo correo a toda la empresa el lunes a las 9:00 AM; en su lugar, la plataforma decide cuál es el mejor momento y el mejor tipo de ataque para cada empleado por separado.

Algunas de sus características y servicios son:

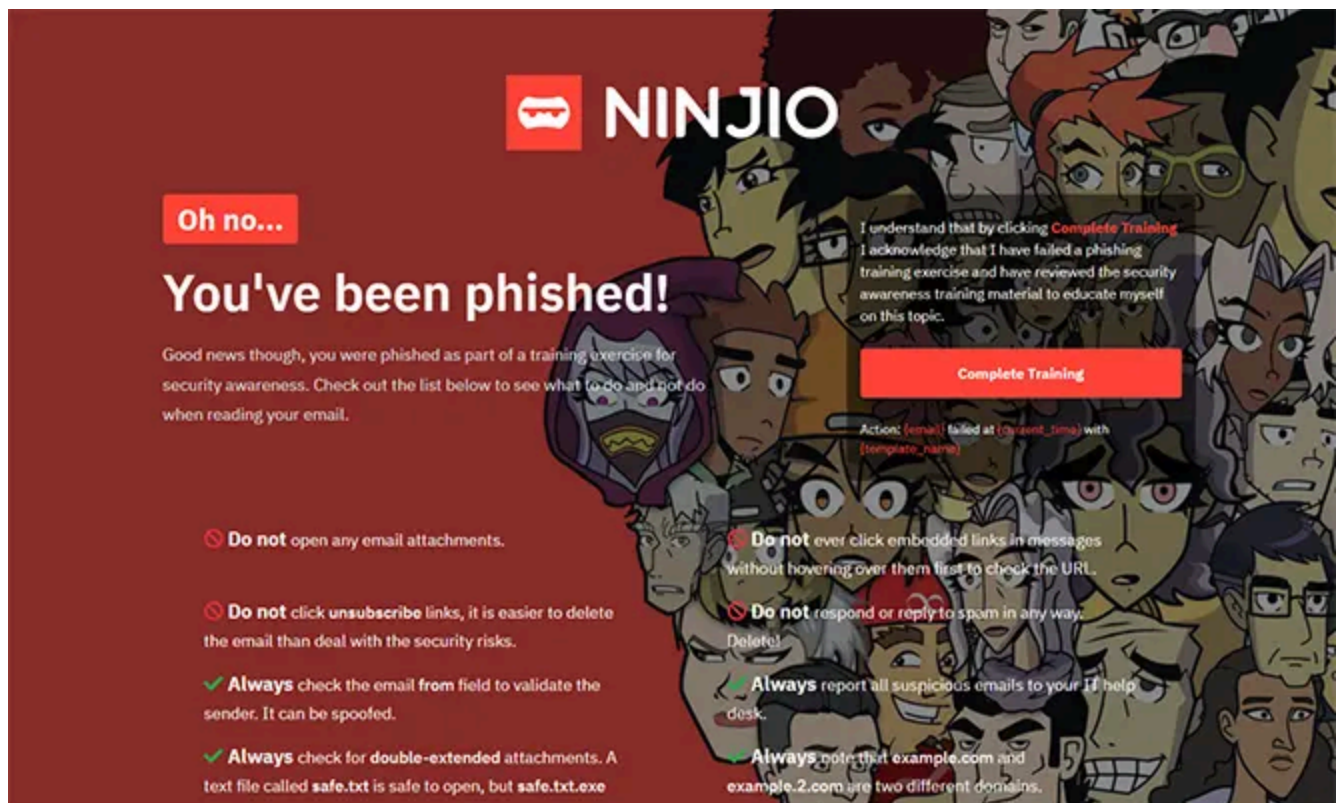
- **Simulaciones Automatizadas:** Envía simulaciones de phishing realistas y personalizadas, adaptadas al contexto y nivel de cada empleado.
- **Aprendizaje Inmediato:** Si un empleado hace clic, se activa un microaprendizaje instantáneo para explicar cómo detectar amenazas futuras.
- **Phished Academy:** Proporciona contenido educativo, incluyendo vídeos, cuestionarios y artículos sobre ciberseguridad para concienciar al personal.
- **Gestión del Riesgo Humano:** Ayuda a identificar y formar a los empleados que más caen en este tipo de trampas, reduciendo los incidentes de seguridad.
- **Asistente de IA (Aria):** Incluye un asistente de ciberseguridad que ofrece soporte 24/7 y guía de incorporación.
- **Botón de Denuncia:** Permite a los usuarios reportar correos sospechosos directamente desde su bandeja de entrada.



NINJIO

Es una plataforma de Gestión del Riesgo Humano (HRM) que utiliza episodios animados de micro aprendizaje (de 3 a 4 minutos) basados en ataques reales que ocurrieron la semana anterior. Su objetivo no es que el usuario memorice una política de seguridad, sino que desarrolle una "intuición cibernética" a través de la narrativa y la emoción. Algunos de sus aspectos clave son los siguientes:

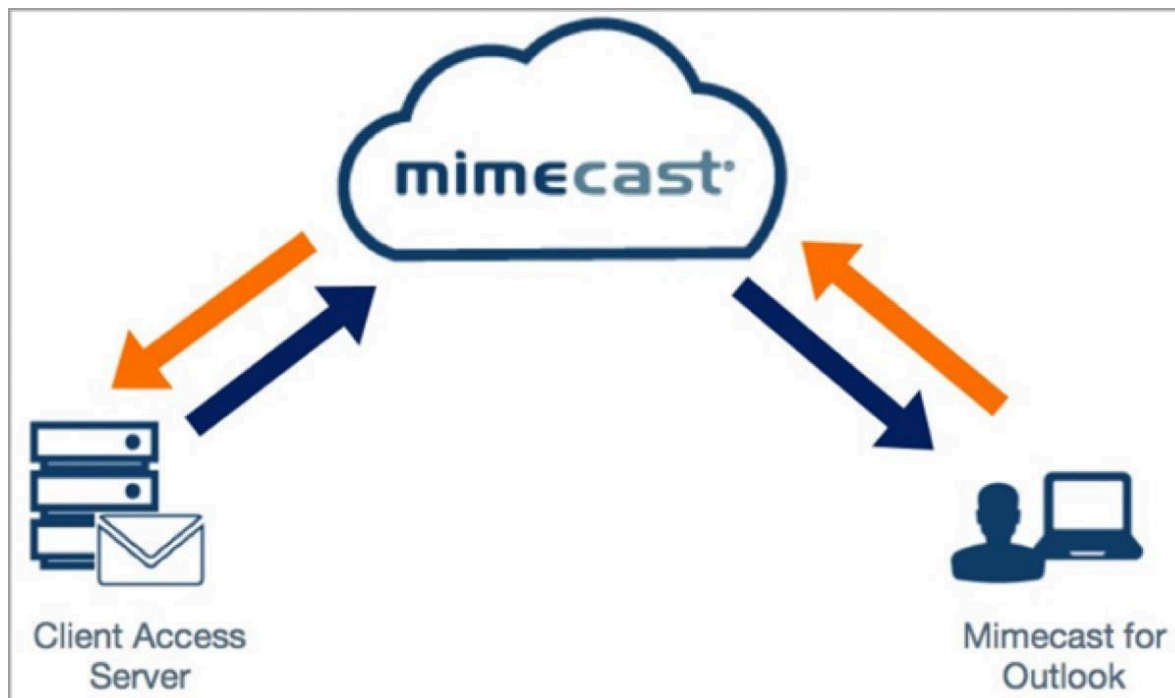
- **Contenido Narrativo:** Utiliza guionistas experimentados para crear historias entretenidas basadas en brechas de seguridad reales.
- **Microaprendizaje Animado:** Vídeos cortos y animados que facilitan el aprendizaje.
- **Enfoque en Riesgo Humano:** Ofrece entrenamiento en concienciación (Aware), simulaciones de phishing (PHISH3D) y coaching personalizado (SENSE) basado en el perfil de susceptibilidad emocional del usuario.
- **Gamificación y Reportes:** Incluye tablas de clasificación para fomentar la participación y herramientas para monitorear el progreso y evaluar riesgos.
- **Uso Personal:** Permite a los usuarios añadir familiares y amigos a la suscripción para extender la protección.



Mimecast

Es una plataforma integral de seguridad en la nube que protege el correo electrónico, los datos y la red. Su división de Security Awareness Training (basada en la adquisición de Ataata) se especializa en cambiar comportamientos mediante contenido altamente entretenido y métricas de riesgo predictivo. Algunas de sus características son:

- **Seguridad de Correo Electrónico:** Protección avanzada (Secure Email Gateway) contra amenazas.
- **Continuidad del Correo Electrónico:** Mantiene el servicio de correo activo incluso durante interrupciones del servidor principal.
- **Archivado en la Nube:** Permite la retención y búsqueda rápida de datos para el cumplimiento normativo
- **Concienciación de Seguridad:** Herramientas para entrenar a empleados contra ataques de ingeniería social.
- **Seguridad Web:** Protege a los usuarios contra sitios web maliciosos, incluso fuera de la red corporativa.



Infosec IQ

Es una plataforma de entrenamiento en seguridad y simulación de phishing que se distingue por su rigor pedagógico y su capacidad de adaptación técnica. Mientras otros se enfocan en que el contenido sea "divertido", Infosec se enfoca en que sea relevante para el puesto de trabajo. No le enseñan lo mismo a un programador que a un recepcionista.

- **Networking simplificado:** Permite conectar con otros asistentes, oradores, patrocinadores y expositores.
- **Agenda Personalizada:** Vista completa del calendario del evento, sesiones y la capacidad de crear un itinerario propio.
- **Programación inteligente:** Herramientas para enviar solicitudes de reuniones y gestionar citas.
- **Actualizaciones en tiempo real:** Recibe notificaciones sobre cambios en la agenda y alertas clave del evento.
- **Herramientas interactivas:** Acceso a mapas, listas de expositores e información de patrocinadores.



Tabla técnica comparativa

A continuación se presenta una tabla comparativa que tiene el propósito de comparar las plataformas de manera técnica en base a 4 puntos.

Plataforma	Analítica Avanzada	Integración técnica	Enfoque ético	Limitaciones críticas
HoxHunt	Seguimiento de rachas (streaks) y niveles de experiencia (XP).	Integración fluida con Microsoft 365 y Google Workspace (botón de reporte).	Prohíbe el castigo; sólo premia el reporte y la detección exitosa. (refuerzo positivo)	Se enfoca casi exclusivamente en phishing, dejando fuera otros temas de ciberseguridad.
Proofpoint	Cruza quién es el más atacado con quién tiene menos formación.	Nativa con su propio Gateway de correo y herramientas de respuesta (TAP/TRAP).	Basado en el cumplimiento (Compliance) y protección de datos de alto nivel.	Es extremadamente cara y difícil de configurar si no usas todo su ecosistema.
KnowBe4	Permite comparar tu "Phish-prone %" con otras empresas del mismo sector.	Muy amplia: AD, Okta, Slack, Teams y casi cualquier LMS (SCORM).	Transparente, aunque su escala masiva puede llevar a un enfoque de	Al tener tanto material, el usuario puede sentirse abrumado o hacer

			"vigilancia".	los cursos por compromiso.
Cofense	Resiliency Score: Mide la velocidad de reporte y la calidad de la alerta humana.	Diseñada para el SOC; integración directa con herramientas de orquestación (SOAR).	No busca "atrapar" al usuario, sino convertirlo en un sensor útil.	Su contenido educativo suele ser menos "atractivo" o visual que el de la competencia
Phished	Zero Incident Index (ZII): Algoritmo predictivo de probabilidad de incidente real.	Automatización de protocolos DMARC/SPF/DKIM integrada.	Privacy by Design: IA que individualiza sin necesidad de que el admin vea datos sensibles.	Al ser 100% automatizada, el administrador tiene poco control sobre qué correo exacto se envía.
NINJIO	Emotional Susceptibility: Identifica qué emoción (miedo, codicia) hace caer al usuario.	Integración con Slack/Teams y sistemas de gestión de aprendizaje (LMS).	Bienestar Digital: Incluye a la familia del empleado; busca proteger el entorno personal.	Su modelo mensual puede ser insuficiente para empresas que necesitan refuerzo semanal.
Mimecast	Encuestas para medir si el empleado se siente seguro o frustrado. (Sentiment Analysis)	Sincronización total con su solución de filtrado y archivado de correo.	Usa la risa para educar sin generar estrés o ansiedad en el trabajador. (Humor no invasivo)	Muchas de sus mejores analíticas requieren que Mimecast sea también tu filtro de correo.
Infosec IQ	Reportes detallados sobre la preparación de departamentos específicos.	API abierta muy robusta; excelente integración con SIEM y herramientas de BI.	Profesionalismo académico: evita el engaño "cruel" y se enfoca en la habilidad laboral.	La plataforma de administración es menos intuitiva y más "técnica" que el resto.

Conclusión

Tras el análisis exhaustivo de las ocho plataformas líderes en el mercado de Gestión del Riesgo Humano (HRM), se hace evidente que la ciberseguridad moderna ha dejado de ser un desafío puramente tecnológico para convertirse en un desafío cultural y psicológico. La premisa de que el usuario es "el eslabón más débil" está siendo sustituida por la visión de que, con el entrenamiento adecuado, el personal puede transformarse en la primera línea de defensa de la organización.

Las principales conclusiones de esta investigación son:

1. **Diversidad de Enfoques:** No existe una solución única. Mientras que Proofpoint e Infosec IQ ofrecen robustez técnica y rigor académico, plataformas como NINJIO y Mimecast demuestran que el storytelling y el humor son herramientas poderosas para combatir la fatiga del usuario y aumentar la retención de conocimientos.
2. **La Métrica del Éxito es el Reporte:** El éxito de una campaña de simulación no debe medirse por cuántos usuarios "cayeron" (Click Rate), sino por cuántos fueron capaces de alertar al equipo de seguridad (Reporting Rate). Empresas como Cofense han demostrado que fomentar una cultura de reporte activo es más valioso que la simple evitación del clic.
3. **Ética y Personalización:** La llegada de la IA Adaptativa (como en Hoxhunt y Phished) permite una individualización del riesgo que respeta los tiempos del usuario, pero exige un marco ético estricto. El consentimiento informado y el refuerzo positivo son pilares innegociables para mantener la confianza entre el departamento de TI y el resto de la empresa.
4. **Integración Sistémica:** Una simulación aislada tiene poco valor. La efectividad real surge cuando los datos de la formación humana se integran con las defensas técnicas (SIEM, SOC, Gateway), permitiendo una respuesta automatizada y coordinada ante incidentes reales.

En conclusión, fortalecer el factor humano requiere un equilibrio entre tecnología avanzada, psicología del comportamiento y un diseño pedagógico ético. Solo así se logra reducir la superficie de ataque en un entorno donde las amenazas de ingeniería social son cada vez más sofisticadas.

Referencias Bibliográficas

- CIRA Cybersecurity Services. (2024, 6 de enero). *How to measure a phishing test program*. CIRA. <https://www.cira.ca/en/resources/news/cybersecurity/phishing-test-metrics-measurement/>
- Cofense. (2024). *Annual State of Phishing Report 2024*. Cofense Resource Center. <https://cofense.com/state-of-phishing-report/>
- Hoxhunt. (2025). *Human Risk Management: The Complete CISO Playbook*. Hoxhunt Oy. <https://hoxhunt.com/guide/human-risk-management-playbook>
- IBM Security. (2024). *Cost of a Data Breach Report 2024*. IBM Corporation. <https://www.ibm.com/reports/data-breach>
- Infosec Institute. (2024). *Security Awareness Training: Role-based learning and compliance*. Infosec IQ. <https://www.infosecinstitute.com/iq/>
- KnowBe4. (2024). *2024 Phishing by Industry Benchmarking Report*. KnowBe4, Inc. <https://www.knowbe4.com/phishing-benchmark-analysis>
- Mimecast. (2025). *The State of Email Security 2025*. Mimecast Services Limited. <https://www.mimecast.com/resources/ebooks/the-state-of-email-security/>
- NDSS Symposium. (2025). *What Makes Phishing Simulation Campaigns (Un)Acceptable? A Vignette Experiment*. Network and Distributed System Security (NDSS). <https://www.ndss-symposium.org/wp-content/uploads/usec25-10.pdf>
- NINJIO. (2024). *The Science of Storytelling in Cybersecurity Awareness*. NINJIO Learning. <https://ninjio.com/resources/>
- Phished. (2024). *Automated Security Awareness: How AI changes the human risk*. Phished.io. <https://phished.io/blog/>

- Proofpoint. (2024). *State of the Phish 2024: An in-depth look at user vulnerability and threat actor tactics*. Proofpoint Inc.
<https://www.proofpoint.com/us/resources/threat-reports/state-of-phish>
- Verizon. (2024). *2024 Data Breach Investigations Report (DBIR)*. Verizon Business.
<https://www.verizon.com/business/resources/reports/dbir/>